

Nathaniel Abera

July 27, 2026

Information Systems Security

A1. The access control method chosen for FinSecure Corp is the Role-Based Access Control (RBAC) model. This model grants permissions to specific roles within the company rather than separate individuals, so every user receives access based on the role assigned to them.

RBAC has three main principles that it follows. These principles are the main structure of the organization's access roles. The first, least privilege, requires each role to hold only the permissions it needs to function properly. Second, separation of duties prevents any single role from overlapping responsibilities, such as both granting and using the same privileged access when only one should be doing so. Third, role consistency requires that every user under an assigned role inherit the same set of permissions.

Each role within FinSecure Corp already has assigned permissions that are organized by job functions. Applying the RBAC model will solidify the structure and allow access to be granted and managed at the role level rather than to individuals.

A2. Misalignment 1: Junior system administrator with Domain Admin privileges. This user role is assigned to J. Lopez, whose job is Junior system administrator with full Domain Admin access across all internal systems. The reason this role conflicts with the RBAC model is because of the principle of least privilege. This principle requires that each role must hold only permissions that it needs to function, but the role Junior administrator does not require domain-wide administrative control and granting it this much privilege gives the account way too much access for what it needs. This can increase the chances of the account being compromised leading to a breach or potential damages within the company.

Misalignment 2: Inconsistent permissions for the Customer support role. This user role is assigned to two people, R. Davis and J. Hall, but J. Hall has more access to the payroll system than R. Davis. This shows the inconsistency between permissions for the same role. As the RBAC principle states, all roles must have consistent access permissions and all users under a specific role must inherit the same set of permissions. A Customer support role has no need to access payroll data. This adds a second layer of misalignment through least privilege, because

the role is being given an additional access privilege that it does not need to function properly. Because one person in this role can access payroll data and the other cannot, the role is no longer linking permissions to one single role. For it to align with the RBAC model, it must have consistent permissions for all users within a specific role in the company.

Misalignment 3: Terminated users with active access permissions in the HR assistant position. The user that has been given this role is P. Ellis, an HR assistant that has a set termination date on May 20, 2025. This user's account is active with read and write access to the HR portal and even the payroll system. This greatly conflicts with the least privilege principle within the RBAC model. Since this user has a set termination date, functionality within the role must be limited. A terminated employee should not be able to access sensitive payroll data, and their active status should have been changed. Because the account was never deactivated, it still retains access that is unnecessary, which leaves an entry point of vulnerability to sensitive payroll data.

Misalignment 4: Account sharing without individual accountability for report_ro. This user role is used for a shared account which isn't tied to a specific person but is a role that's mapped to general reporting. This makes identifying accountability difficult because multiple users operate under one login, so their activity cannot be properly traced back to a specific individual. A shared account completely breaks the structure that the RBAC model is designed to follow. Activity can't be traced back to an individual, since the report_ro permissions are given to multiple users.

A3. The first recommendation I would make for FinSecure Corp is that they should begin reviewing their permissions again for each role and make sure to reduce the amount of access some users have because as identified earlier, there are multiple users that have access they shouldn't have and it is critical that they fix it. This includes the Junior system administrator role (Misalignment 1) and the Customer support role (Misalignment 2). The junior system administrator should be downgraded from a Domain Admin and access to payroll data should be removed from the Customer support role. Once this change is done it will align with NIST SP 800-53 control AC-6 (NIST, 2020), which informs companies to only grant users access needed for the role to function properly.

The second recommendation for FinSecure Corp is that they should deactivate accounts as soon as an employee is set for termination. If a user is scheduled for termination, they shouldn't be given access to specific roles that relate to sensitive permissions such as the identified Misalignment 3. Creating a function that automatically deactivates user's permission

based on the end date of their employment and ensuring that the role will not have any access beyond that date will align with NIST SP 800-53 control AC-2 (NIST, 2020), which requires companies to manage the lifecycle of the full account and disable accounts when they are no longer needed.

The third recommendation for FinSecure Corp is that they should be converting shared accounts into individual accounts so that accountability can be tracked. As identified in misalignment 4, report_ro is a permission linked to multiple users, allowing them to have read-only access to reporting information. This activity isn't tracked, which makes it difficult to hold users accountable for certain actions. If this change is made and users are no longer able to use shared accounts then it will align with NIST SP 800-53 control IA-2 (NIST, 2020), which requires information systems to uniquely identify and authenticate individual users.

A4.

User	Role	Access	Account Status
J. Lopez	Junior system administrator	Support access (Domain Admin Removed)	Active
R. Davis	Customer Support Rep	CRM and Email Server	Active
J. Hall	Customer Support Rep	CRM and Email Server (Payroll access removed)	Active
P. Ellis	HR Assistant	Access revoked	Deactivated
Report_ro	Switched to individual accounts	Read-only reporting assigned to users	Active
A. Jones	Finance manager	Payroll system, budget tracker	Active

L. Cheng	Finance analyst	Payroll system, budget tracker, CRM	Active
M. Singh	HR coordinator	HR portal, payroll system	Active
K. Patel	Security analyst	SIEM, network logs, firewall console	Active
T. Miller	IT administrator	All internal systems	Active
D. Nguyen	External auditor	Budget tracker	Deactivated
C. Wright	Marketing manager	Email server, CRM	Active
S. Kumar	Business analyst	Budget tracker, CRM	Active
R. Lee	Network engineer	Firewall console, VPN gateway	Active
T. Nguyen	Compliance officer	Audit logs, policy repository	Active
M. Brown	Contractor - IT audit	SIEM, network logs	Active
H. Alvarez	Payroll specialist	Payroll system	Active
E. Romero	Data engineer	Data warehouse, SFTP gateway	Active
svc_payroll_etl	Service account - Payroll ETL	SFTP gateway, payroll system API	Active

vendor_finapp	Vendor support - Finance app	VPN gateway, finance app server	Active
B. Ortiz	Help desk technician	Ticketing tool, AD users and computers	Active
J. Carter	QA analyst	Staging web app, test DB	Active
L. Smith	Facilities coordinator	Badge system, work order system	Active
P. Rivera	Intern - Marketing	Email server, share drive (marketing)	Active

The revised access control that would be made reflects the RBAC model. In A3, it was covered that the Junior system administrator role should be downgraded from Domain Admin, the Customer support role should have its access to payroll data removed, the terminated HR assistant account needs to be deactivated, and last the shared report_ro account needs to be replaced with individual accounts only.

B1. The first gap is that the access control policy for FinSecure Corp says that reviews of access controls are only conducted as-needed. This means that there are no regular checks on access controls. The problem with this is that this affects access management because permissions are most likely never reviewed and it allows employees to change roles and elevate their privileges without any manager authorization. Over time, this adds up and it can snowball, a condition formally known as privilege creep. The second gap within the policy is that it states access to the logs is unrestricted. This affects operational security because it allows any user to view sensitive records and alter evidence that may be needed to detect misuse. The third gap is that shared accounts are being used instead of individual accounts in order to save money on licensing costs. This affects access management because shared accounts make it difficult to enforce individual accountability. It also contradicts itself because the policy has an access control section which gives certain permissions to specific roles for its users.

B2. To fix the first gap, FinSecure should update its policy and begin requiring regular

scheduled checks, where users' permissions are being re-evaluated every quarter to ensure that it aligns with ISO/IEC 27001:2022 Annex A controls 5.15 through 5.18 (ISO, 2022) and CIS Control 6 (CIS, 2024). The best way to fix the second gap is by revising log access and only allowing authorized security personnel to gain access instead of leaving it unrestricted. This will align with NIST SP 800-53 control AU-9 (NIST, 2020), which requires audit information to be protected from unauthorized access. For the third gap, the policy needs to require individual accounts to access the company systems rather than allowing users to use shared accounts because this allows for user activity to be properly documented. This aligns with NIST SP 800-53 control IA-2 (NIST, 2020), which requires the company system to identify and authenticate individual users.

C. Operational Process Gap Evaluation

The change management process is the first weakness for FinSecure because there is no formal requirement to make changes with manager approval. So, any changes in the ticket system or emergency changes can be made without it being documented or approved by a manager. The logs themselves detail this gap and show that the firewall rule modification by the user t.miller was recorded but there was no ticket ID associated with this activity. This clearly undermines the integrity of company information because not documenting these kinds of changes may lead to unauthorized configurations that can't be traced back and go undetected. Implementing a requirement of documentation and manager approval will improve this weakness and align with NIST SP 800-53 control CM-3 (NIST, 2020).

The second weakness that FinSecure must improve is its security awareness training for employees. Most employees only receive a short email once every year, and there are no other forms of exercises that happen throughout the year (such as phishing simulations or practice exercises, or even a team meeting regarding the topic). This greatly affects the confidentiality of the company's information because employees who are not trained to identify any phishing attempts are more likely to accidentally become victims of an attack. This in return will expose sensitive information and data they are required to protect. To improve this, implementing security awareness training regularly throughout the year will keep employees aware, and this will align with NIST SP 800-53 control AT-2 (NIST, 2020).

The third weakness that FinSecure faces is asset management. The company offers laptops to assigned employees, but the problem is that there is no inventory database that documents the usage of devices. If an employee is terminated, the device still may contain sensitive company data and because there is no formal process for wiping the devices, this leaves certain

information to be accessed by unauthorized users outside the company. To improve this weakness, FinSecure needs to maintain regular inventory checks, require wiping of returned devices, and verify devices are returned after termination. This will align with NIST SP 800-53 control MP-6 (NIST, 2020).

D1. Threat 1: Brute force attack made against a user account. Based on the logs a brute force attack was made against an account of J. Hall on the date of June 29 at 08:47am. An authentication failure was also recorded for the user j.hall from an IP address: 185.63.145.20. This attempt was made five times and failed five times due to an invalid password and about 3 minutes later at 08:50am, a successful login was last recorded for the same account via the same IP address. But what was flagged was the geolocation because it was marked as unknown and it was outside a normal range of the account's geolocation. Following that in the morning at 08:15 another suspicious activity was logged regarding a DNS query for the same user to the domain xyz-malware.com. This was matched as malicious. This pattern of repeated failed attempts followed by a successful login from an unusual location is classified as a brute force attempt and a domain lookup as well indicates this account was compromised.

Threat 2: Self-granted admin privileges that seem to be from an insider. By looking at the logs, an event involving J. Lopez has been recorded and seems to be unusual activity from this user account. On June 29 at 10:25am, the directory service showed a PRIV_ESCALATION entry where the user j.lopez was given Domain Admin privileges, with the target account also being listed as j.lopez and the action being recorded as a manual change. Because the user granting the privilege and the account receiving it belong to the same person, this action bypassed any approval process by a separate user and was done within the company. This is classified as an insider threat and it involves a user misusing privileges to expand their own access controls.

Threat 3: Remote access trojan was detected on an internal host which indicates malware. A third threat that was discovered within the logs is that a malware infection had been detected. The SIEM had detected a MALWARE_ALERT that had been recorded for host 10.1.1.45 on the date of June 29 at 14:54. It identified the malware family of this alert as GhostX RAT with a severity level of HIGH and the signature ID was GX-3492. This type of malware was designed to give attackers control of an infected system through a remote access trojan. This puts all internal data and systems at risk. But earlier on that same day at 11:47, another alert was recorded, but it was cleared by user k.patel and marked as a false positive. This raises the possibility that the user k.patel had seen this alert but did not take the correct action needed to address this concern before the confirmed detection. After analyzing the logs and the

signatures, this has been identified as a malware-based threat.

D2. A mitigation strategy for the brute force threat against the account of J. Hall requires FinSecure to enforce an automatic account lockout procedure that will lock accounts after a set number of failed login attempts and to add multi-factor authentication which prevents access from stolen passwords alone. All credentials that have been compromised must also be reset. Once all these steps are complete, this strategy aligns with CIS Control 6 (CIS, 2024), which entails access control management and strengthened user authentication. This also aligns with the NIST Risk Management Framework (NIST, 2018) as it ensures any identified risks are well contained and will be continuously monitored to prevent future reoccurrences.

For J. Lopez, FinSecure can mitigate the insider threat by requiring all access to grant privileges to be made through a separate administrator that will document each approval. This will prevent users from granting themselves permission independently and require users to contact a separate administrator for additional access control privileges. This strategy is supported by the principles reflected in NIST SP 800-53 controls AC-5 and AC-6 (NIST, 2020), least privilege and separation of duties. These principles require every user to only have the access they need to properly function in their given role. Once this strategy is implemented and applied within the NIST Risk Management Framework, it will ensure that any future privilege changes are made by authorized users rather than self-elevated.

The mitigation strategy for the malware threat requires FinSecure to isolate the host 10.1.1.45 from the network and remove the GhostX RAT infection. Afterwards, deploying an endpoint detection and response system across all the other internal hosts must be done to find any other similar activity on the network. The company needs to require that all alerts are verified by a second analyst before users clear them as false positives. Once this strategy is implemented, it will align with CIS Control 10 (CIS, 2024), which details malware defenses made through automated response and detection systems. This follows the steps recommended by the NIST Risk Management Framework.

References

Center for Internet Security. (2024). *CIS critical security controls version 8.1*.
<https://www.cisecurity.org/controls/v8-1>

International Organization for Standardization. (2022). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (ISO/IEC 27001:2022). <https://www.iso.org/standard/27001>

National Institute of Standards and Technology. (2018). *Risk management framework for information systems and organizations: A system life cycle approach for security and privacy* (NIST Special Publication 800-37, Rev. 2). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-37r2>

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Rev. 5). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-53r5>